

MAGNA · SECURITY REVIEW

Magna Hook Updates.

A security review of Hook Updates.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Magna	Hook Updates	Guardian	October 14 – October 24, 2024	October 31, 2024

§ 00

Contents.

17 pages — overview, confidence ranking, scope, 8 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 6 findings	P. 08
	Remediation Review · 2 findings	P. 14
§ 05	Disclaimer	P. 16
§ 06	About Guardian	P. 17

§ 01

Overview.

Guardian reviewed Hook Updates across 2 review rounds. The final report includes 1 Critical, 7 Low findings.

AUDIT FIRM	Guardian	REPOSITORY	magna-eng/protocol
CLIENT	Magna	METHODOLOGY	Smart contract · Manual · Main Review · Remediation Review
PROJECT	Hook Updates	MAIN REVIEW COMMIT	62a1d7f39a8d
PREPARED BY	Guardian	REMEDATION REVIEW COMMIT	c2ad12858b5d
AUDIT WINDOW	October 14 – October 24, 2024		
FINAL REPORT	October 31, 2024		

1.1 Confidence Ranking

3 / 5

Moderate Confidence

Guardian assigns a Confidence Ranking of 3 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
■ Critical	1	0	0	0	1
■ High	0	0	0	0	0
■ Medium	0	0	0	0	0
■ Low	7	0	1	0	6
■ Informational	0	0	0	0	0
All severities	8	0	1	0	7

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence ASSIGNED	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Hook Updates in `magna-eng/protocol`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH
Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM
Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW
Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH
Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM
Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW
Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
C-01	Insufficient postClaimHandler validation	Validation	CRITICAL	RESOLVED	p. 8
L-01	withdraw() Can Be Unusable	Informational	LOW	RESOLVED	p. 9
L-02	Typos In Errors	Typographical Error	LOW	RESOLVED	p. 10
L-03	getPostClaimHandlers return value	Return value	LOW	RESOLVED	p. 11
L-04	Incomplete withdraw NatSpec	NatSpec	LOW	RESOLVED	p. 12
L-05	Use Stack Variable For postClaimHandlers	Gas Optimization	LOW	RESOLVED	p. 13
REMEDIATION REVIEW					
L-01	Comment On Wrong Withdraw	Documentation	LOW	RESOLVED	p. 14
L-02	Fee Paid Overwritten	Warning	LOW	ACKNOWLEDGED	p. 15

CRITICAL **C-01**

RESOLVED

Insufficient postClaimHandler validation

CATEGORY	Validation
LOCATION	IAirlockBase.sol
REVIEW	Main Review

DESCRIPTION

[IAirlockBase](https://github.com/GuardianAudits/magna-hooks/blob/62a1d7f39a8d1b1f6e13a7f55237d4d3470d12c3/evm/src/distribution/V2/2.1.0/src/interfaces/IAirlockBase.sol#L70-L86) has a `postClaimHandlerWhitelist` set which includes the whitelisted postClaim handlers added by the trusted role.

However, when `[_withdrawToBeneficiary]`(https://github.com/GuardianAudits/magna-hooks/blob/62a1d7f39a8d1b1f6e13a7f55237d4d3470d12c3/evm/src/distribution/V2/2.1.0/src/interfaces/IAirlockBase.sol#L141-L156) is called, it's not checked that the handler is whitelisted. This allows anyone to bypass the postClaim handlers by setting their own contract as the handler and effectively perform direct claims even if they are disallowed.

RECOMMENDATION

Before claiming, ensure the `postClaimHandler` is whitelisted. In addition, consider if the `extraData` passed should also be validated.

RESOLUTION

Status: Resolved.

<https://github.com/magna-eng/protocol/pull/21/commits/99c6dd658ad94a20c0bd4a03aa3993ce7c134806>

LOW **L-01**

RESOLVED

withdraw() Can Be Unusable

CATEGORY Informational
LOCATION CalendarV2::L138
REVIEW Main Review

DESCRIPTION

`withdraw(string calldata _id, uint256 _requestedWithdrawalAmount)` calls `withdraw(string calldata _id, uint256 _requestedWithdrawalAmount, IPostClaimHandler postClaimHandler, bytes memory extraData)` with `postClaimHandler` hardcoded to address 0.

If `DIRECT_CLAIM_ALLOWED` has not been added to `postClaimHandlerWhitelist`, this will cause a revert inside of `_withdrawToBeneficiary`.

RECOMMENDATION

Document to users that they must call the proper `withdraw()` function when `DIRECT_CLAIM_ALLOWED` is not allowed.

RESOLUTION

Status: Resolved.

<https://github.com/magna-eng/protocol/pull/22/commits/43a276c9d757719b5d2d592044de2171730f28b8>

LOW **L-02**

RESOLVED

Typos In Errors

CATEGORY	Typographical Error
LOCATION	IAirlockBase.sol: 70-86
REVIEW	Main Review

DESCRIPTION

The errors `ClaimHandlerAlreadyWhitlested` and `ClaimHandlerNotYetWhitlested` should be corrected to `ClaimHandlerAlreadyWhitelisted` and `ClaimHandlerNotYetWhitelisted` respectively.

RECOMMENDATION

Correct the typos according to the above.

RESOLUTION

Status: Resolved.

<https://github.com/magna-eng/protocol/pull/22/commits/43a276c9d757719b5d2d592044de2171730f28b8>

LOW **L-03**

RESOLVED

getPostClaimHandlers return value

CATEGORY	Return value
LOCATION	IAirlockBase
REVIEW	Main Review

DESCRIPTION

`IAirlockBase.getPostClaimHandlers()` will return an array which includes `address(0)` when direct claim is enabled. Having this value in the array may be unexpected for third parties integrating with the contracts. For example, they may be calling some function on each handler. Then they will call it on `address(0)` and the tx will revert.

RECOMMENDATION

Make sure to document this behavior

RESOLUTION

Status: Resolved.

<https://github.com/magna-eng/protocol/pull/22/commits/43a276c9d757719b5d2d592044de2171730f28b8>

LOW **L-04**

RESOLVED

Incomplete withdraw NatSpec

CATEGORY NatSpec
LOCATION Global
REVIEW Main Review

DESCRIPTION

The changed `withdraw` functions don't include the `postClaimHandler` and `extraData` parameters in their NatSpecs.

RECOMMENDATION

Add these two parameter to the NatSpecs.

RESOLUTION

Status: Resolved.

<https://github.com/magna-eng/protocol/pull/22/commits/43a276c9d757719b5d2d592044de2171730f28b8>

LOW **L-05**

RESOLVED

Use Stack Variable For postClaimHandlers

CATEGORY Gas Optimization
LOCATION IAirlockBase::L61
REVIEW Main Review

DESCRIPTION

`postClaimHandlers` is a memory array that uses `postClaimHandlerWhitelist.length()` to set the length of the array. However, on the previous line, the size is already stored as a stack variable. It is cheaper to use that variable than to call `postClaimHandlerWhitelist.length()`.

RECOMMENDATION

Use `arrLength` to set the size of the array for `postClaimHandlers`.

RESOLUTION

Status: Resolved.

<https://github.com/magna-eng/protocol/pull/22/commits/43a276c9d757719b5d2d592044de2171730f28b8>

LOW **L-01**

RESOLVED

Comment On Wrong Withdraw

CATEGORY Documentation
LOCATION IAirlockV2.sol: 45
REVIEW Remediation Review

DESCRIPTION

The comment "@dev if direct claim feature is disabled, then this method should not be called" was added for the `withdraw` function with a `postClaimHandler` parameter rather than the `withdraw` function defaulting the handler to `address(0)`.

RECOMMENDATION

Place the comment for `function withdraw(string calldata _id, uint256 _withdrawalAmount)` `external virtual;` instead.

RESOLUTION

Status: Resolved.

LOW **L-02**

ACKNOWLEDGED

Fee Paid Overwritten

CATEGORY Warning
LOCATION MerkleVester.sol
REVIEW Remediation Review

— DESCRIPTION

Both Calendar and Interval allocations use the same `feeAlreadyPaid` mapping. If a Calendar and Interval have the same allocation id's, the fee paid would potentially be set and a claim fee would not be paid for the allocation.

— RECOMMENDATION

Ensure allocation ID's are unique.

— RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.